

THREAT INTELLIGENCE REPORT

Analisi di una cattura di traffico di rete e identificazione degli Indicatori di Compromissione (IOC)

File analizzato: Cattura_U3_W1_L5.pcapng

Strumento di analisi: Wireshark

Autore: Salvatore Frisicaro

Corso / Modulo: Unità 3 – Settimana 1 – Lezione 5

Data: 07/08/2026

1. Sommario esecutivo

La presente relazione documenta l'analisi di una cattura di traffico di rete (Cattura_U3_W1_L5.pcapng), effettuata con Wireshark, allo scopo di identificare eventuali Indicatori di Compromissione (IOC) e formulare ipotesi motivate sul vettore di attacco impiegato.

L'analisi ha rilevato in modo inequivocabile un'attività di port scanning automatizzato: un host della rete (192.168.200.100) ha sondato oltre mille porte TCP dell'host 192.168.200.150 in una finestra temporale di circa 0,1 secondi, rivelando tredici servizi attivi, alcuni dei quali legacy e notoriamente insicuri. Tale attività è riconducibile alla fase di ricognizione (reconnaissance) di una potenziale catena di attacco, propedeutica allo sfruttamento di vulnerabilità sui servizi individuati.

Nei paragrafi seguenti vengono presentati la metodologia di analisi, gli IOC identificati, le ipotesi sul vettore di attacco e le azioni di mitigazione raccomandate.

2. Metodologia di analisi

La cattura è stata analizzata tramite Wireshark, utilizzando in sequenza: la finestra Statistics > Protocol Hierarchy per una panoramica dei protocolli presenti; la finestra Statistics > Conversations per individuare gli host coinvolti e il volume di connessioni; filtri di visualizzazione mirati (tcp.flags.syn==1, tcp.flags.reset==1, arp) per isolare i pattern di traffico anomali; l'ispezione dei singoli flussi TCP (Follow TCP Stream) per verificare l'assenza o presenza di payload applicativo.

Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Packets A + B	Bytes A + B	Packets B + A	Bytes B + A	Rel Start	Duration	Bits/s A + B	Bits/s B + A	Flows
192.168.200.100	32792	192.168.200.150	218	2	134 bytes	526	1	74 bytes	1	60 bytes	36.829886644	0.000219			0
192.168.200.100	32794	192.168.200.150	641	2	134 bytes	831	1	74 bytes	1	60 bytes	36.870237021	0.000208			0
192.168.200.100	32820	192.168.200.150	49	2	134 bytes	518	1	74 bytes	1	60 bytes	36.828835954	0.000077			0
192.168.200.100	32852	192.168.200.150	688	2	134 bytes	948	1	74 bytes	1	60 bytes	36.871590052	0.000220			0
192.168.200.100	32896	192.168.200.150	890	2	134 bytes	637	1	74 bytes	1	60 bytes	36.838767957	0.000207			0
192.168.200.100	32912	192.168.200.150	382	2	134 bytes	287	1	74 bytes	1	60 bytes	36.806271198	0.000285			0
192.168.200.100	32922	192.168.200.150	401	2	134 bytes	999	1	74 bytes	1	60 bytes	36.870598377	0.000245			0
192.168.200.100	32950	192.168.200.150	570	2	134 bytes	74	1	74 bytes	1	60 bytes	36.782255091	0.000076			0
192.168.200.100	32976	192.168.200.150	690	2	134 bytes	734	1	74 bytes	1	60 bytes	36.848544607	0.000270			0
192.168.200.100	32996	192.168.200.150	1021	2	134 bytes	425	1	74 bytes	1	60 bytes	36.819979259	0.000327			0
192.168.200.100	33042	192.168.200.150	445	4	280 bytes	15	3	206 bytes	1	74 bytes	36.776385694	0.001508			0
192.168.200.100	33050	192.168.200.150	448	2	134 bytes	809	1	74 bytes	1	60 bytes	36.855529585	0.000202			0
192.168.200.100	33050	192.168.200.150	373	2	134 bytes	826	1	74 bytes	1	60 bytes	36.857269199	0.000206			0
192.168.200.100	33056	192.168.200.150	521	2	134 bytes	157	1	74 bytes	1	60 bytes	36.792678781	0.000169			0
192.168.200.100	33058	192.168.200.150	411	2	134 bytes	270	1	74 bytes	1	60 bytes	36.804716539	0.000187			0
192.168.200.100	33058	192.168.200.150	299	2	134 bytes	511	1	74 bytes	1	60 bytes	36.828372043	0.000324			0
192.168.200.100	33102	192.168.200.150	51	2	134 bytes	79	1	74 bytes	1	60 bytes	36.782562077	0.000272			0
192.168.200.100	33114	192.168.200.150	248	2	134 bytes	262	1	74 bytes	1	60 bytes	36.803842536	0.000174			0
192.168.200.100	33206	192.168.200.150	143	2	134 bytes	18	1	74 bytes	1	60 bytes	36.774496366	0.000409			0
192.168.200.100	33250	192.168.200.150	355	2	134 bytes	299	1	74 bytes	1	60 bytes	36.807513044	0.000225			0
192.168.200.100	33260	192.168.200.150	962	2	134 bytes	224	1	74 bytes	1	60 bytes	36.807426583	0.000220			0
192.168.200.100	33332	192.168.200.150	238	2	134 bytes	366	1	74 bytes	1	60 bytes	36.813553383	0.000332			0
192.168.200.100	33384	192.168.200.150	1020	2	134 bytes	640	1	74 bytes	1	60 bytes	36.839439377	0.000214			0
192.168.200.100	33430	192.168.200.150	577	2	134 bytes	193	1	74 bytes	1	60 bytes	36.796308835	0.000183			0
192.168.200.100	33452	192.168.200.150	77	2	134 bytes	744	1	74 bytes	1	60 bytes	36.849410409	0.000130			0
192.168.200.100	33460	192.168.200.150	112	2	134 bytes	673	1	74 bytes	1	60 bytes	36.842748811	0.000176			0
192.168.200.100	33566	192.168.200.150	63	2	134 bytes	305	1	74 bytes	1	60 bytes	36.802643166	0.000161			0
192.168.200.100	33618	192.168.200.150	91	2	134 bytes	960	1	74 bytes	1	60 bytes	36.872641249	0.000273			0
192.168.200.100	33698	192.168.200.150	815	2	134 bytes	358	1	74 bytes	1	60 bytes	36.832323116	0.000203			0
192.168.200.100	33718	192.168.200.150	359	2	134 bytes	83	1	74 bytes	1	60 bytes	36.785943368	0.000307			0
192.168.200.100	33782	192.168.200.150	172	2	134 bytes	272	1	74 bytes	1	60 bytes	36.805266735	0.000121			0
192.168.200.100	33876	192.168.200.150	443	2	134 bytes	1	1	74 bytes	1	60 bytes	23.764287789	0.000490			0
192.168.200.100	33878	192.168.200.150	443	2	134 bytes	4	1	74 bytes	1	60 bytes	36.774257841	0.000428			0
192.168.200.100	33884	192.168.200.150	408	2	134 bytes	620	1	74 bytes	1	60 bytes	36.837044822	0.001125			0
192.168.200.100	33896	192.168.200.150	763	2	134 bytes	149	1	74 bytes	1	60 bytes	36.791995935	0.000169			0
192.168.200.100	33900	192.168.200.150	714	2	134 bytes	757	1	74 bytes	1	60 bytes	36.850221970	0.000711			0
192.168.200.100	33910	192.168.200.150	511	2	134 bytes	222	1	74 bytes	1	60 bytes	36.800509125	0.000284			0
192.168.200.100	33948	192.168.200.150	390	2	134 bytes	957	1	74 bytes	1	60 bytes	36.872281850	0.000226			0
192.168.200.100	33950	192.168.200.150	720	2	134 bytes	937	1	74 bytes	1	60 bytes	36.870886848	0.000138			0
192.168.200.100	33994	192.168.200.150	620	2	134 bytes	961	1	74 bytes	1	60 bytes	36.872660204	0.000254			0
192.168.200.100	34004	192.168.200.150	528	2	134 bytes	203	1	74 bytes	1	60 bytes	36.797483249	0.000347			0
192.168.200.100	34022	192.168.200.150	843	2	134 bytes	718	1	74 bytes	1	60 bytes	36.847268711	0.000212			0
192.168.200.100	34034	192.168.200.150	833	2	134 bytes	395	1	74 bytes	1	60 bytes	36.816348279	0.000164			0
192.168.200.100	34030	192.168.200.150	1005	2	134 bytes	843	1	74 bytes	1	60 bytes	36.861457795	0.000351			0
192.168.200.100	34064	192.168.200.150	96	2	134 bytes	421	1	74 bytes	1	60 bytes	36.810202672	0.000636			0
192.168.200.100	34094	192.168.200.150	645	2	134 bytes	462	1	74 bytes	1	60 bytes	36.841511712	0.000255			0
192.168.200.100	34120	192.168.200.150	98	2	134 bytes	26	1	74 bytes	1	60 bytes	36.777302991	0.000320			0
192.168.200.100	34130	192.168.200.150	230	2	134 bytes	979	1	74 bytes	1	60 bytes	36.874530681	0.000191			0
192.168.200.100	34180	192.168.200.150	666	2	134 bytes	234	1	74 bytes	1	60 bytes	36.870573606	0.000193			0

3. Host coinvolti

La cattura coinvolge due soli host attivi sulla rete locale 192.168.200.0/24, entrambi identificati da indirizzi MAC con prefisso 08:00:27 (OUI Oracle VirtualBox), a conferma che si tratta di un ambiente di laboratorio virtualizzato:

- 192.168.200.100 (MAC 08:00:27:39:7d:fe) — host sorgente della scansione, verosimilmente la macchina dell'attaccante.
- 192.168.200.150 (MAC 08:00:27:fd:87:1e) — host target/vittima, oggetto della scansione.

I quattro pacchetti ARP presenti in cattura sono normali richieste/risposte di risoluzione indirizzo-MAC (rapporto 1:1 richiesta/risposta) e non presentano alcuna anomalia riconducibile ad ARP spoofing o poisoning.

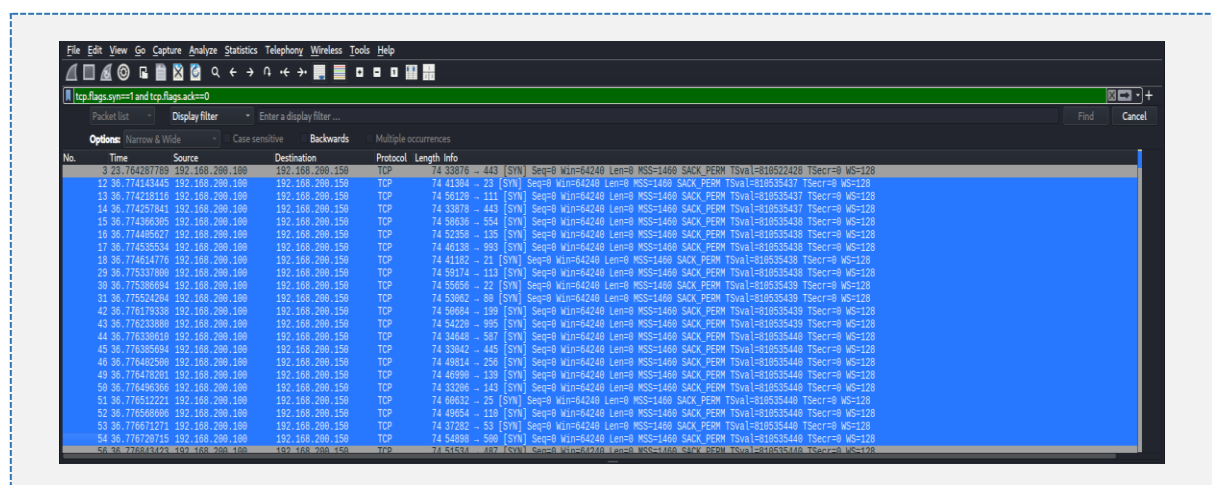
4. Indicatori di compromissione (IOC) identificati

4.1 IOC comportamentale: volume e velocità delle connessioni

Sono stati osservati 1026 pacchetti SYN inviati da 192.168.200.100 verso 192.168.200.150, distribuiti su un intervallo temporale di appena circa 0,104 secondi (da t=36,774s a t=36,878s della cattura). Un simile volume di tentativi di connessione concentrati in una finestra così ristretta non è compatibile con traffico applicativo legittimo generato da un utente o da un servizio, ed è la firma tipica di un tool di scansione automatizzata delle porte (ad es. Nmap, con profilo di timing aggressivo -T4/-T5, o strumenti equivalenti come masscan).

4.2 IOC comportamentale: pattern di connessione anomalo

Per ciascuna porta sondata si osserva sistematicamente lo stesso schema: SYN → SYN-ACK (o RST-ACK se la porta è chiusa) → ACK → RST immediato, senza alcuno scambio di dati applicativi. L'apertura e la chiusura istantanea della connessione, ripetuta identica su centinaia di porte consecutive, è coerente con una scansione TCP (connect scan / SYN scan) e non con l'utilizzo reale di un servizio.



4.3 IOC statico: superficie applicativa esposta dal target

Le risposte SYN-ACK ricevute da 192.168.200.150 rivelano tredici porte TCP aperte, riportate nella tabella seguente. L'elenco corrisponde al set di servizi tipicamente esposto da sistemi volutamente vulnerabili usati a scopo didattico/di test, con la compresenza di servizi legacy e insicuri (Telnet, r-services) che costituisce di per sé un fattore di rischio significativo.

Porta	Servizio	Rilevanza / rischio
21	FTP	Trasmissione credenziali in chiaro; storicamente soggetta a backdoor note (es. vsftpd 2.3.4).
22	SSH	Servizio amministrativo remoto; da esporre solo a IP fidati.
23	Telnet	Protocollo non cifrato: credenziali e dati in chiaro. Servizio legacy da dismettere.
25	SMTP	Possibile uso per relay di spam o enumerazione utenti.
53	DNS	Possibile ricognizione della zona / DNS non protetto.
80	HTTP	Superficie applicativa web, potenziale ulteriore vettore di attacco.
111	RPCbind	Espone i servizi RPC registrati; frequente vettore di enumerazione/exploit.
139 / 445	SMB / NetBIOS	Storicamente soggetto a exploit critici (es. EternalBlue) e relay di autenticazione.
512 / 513 / 514	rexec / rlogin / rsh (r-services)	Servizi obsoleti con autenticazione debole/in chiaro; da disabilitare.

4.4 IOC comportamentale: ricognizione preliminare mirata

Circa 13 secondi prima della scansione massiva ($t \approx 23,76s$), lo stesso host 192.168.200.100 invia due pacchetti SYN isolati verso le sole porte 80 e 443 di 192.168.200.150. Questo comportamento è coerente con una fase preliminare di host discovery (verifica che il target sia raggiungibile e risponda su protocolli web), tipica della ricognizione manuale che precede il lancio di una scansione automatizzata più estesa.

5. Ipotesi sul vettore di attacco

Sulla base degli IOC raccolti, l'attività osservata è classificabile come fase di Reconnaissance nel modello della Cyber Kill Chain, propedeutica ma non ancora costitutiva di un attacco con impatto diretto. Non risultano infatti, nella cattura analizzata, scambi di payload applicativo, tentativi di autenticazione o comandi riconducibili allo sfruttamento (exploitation) di una vulnerabilità specifica.

1. Port scanning con Nmap (o tool equivalente): il pattern temporale (oltre 1000 SYN in ~0,1s) e la copertura sistematica delle porte 1-1024 sono coerenti con una scansione automatizzata ad alta velocità, verosimilmente Nmap con profilo di timing aggressivo.
2. Fingerprinting dei servizi come preludio a exploitation mirata: la presenza contemporanea di servizi legacy vulnerabili (Telnet, FTP, SMB, r-services) suggerisce che l'attaccante stia raccogliendo informazioni per selezionare, in una fase successiva non presente in questa cattura, l'exploit più idoneo (ad es. contro FTP, SMB o Telnet).
3. Ambiente di test/laboratorio: gli indirizzi MAC con OUI VirtualBox indicano che la cattura è stata generata in un ambiente virtualizzato controllato, verosimilmente a scopo didattico (es. macchina attaccante tipo Kali Linux contro un target volutamente vulnerabile tipo Metasploitable).

6. Raccomandazioni e azioni di mitigazione

6.1 Rilevamento e risposta immediata

- Implementare un sistema IDS/IPS (es. Snort, Suricata) con regole dedicate al rilevamento di port scan, basate su soglie di pacchetti SYN/RST anomali da un singolo host in una finestra temporale ristretta.
- Configurare alert automatici e rate limiting (es. fail2ban o equivalente) per bloccare temporaneamente l'IP sorgente al superamento di soglie di connessione sospette.
- Integrare gli IOC individuati (IP sorgente, pattern temporale, elenco porte target) in un sistema SIEM per la correlazione con eventuali eventi successivi riconducibili allo stesso attore.

6.2 Riduzione della superficie di attacco (hardening)

- Disabilitare i servizi non necessari, in particolare i protocolli legacy non cifrati (Telnet, r-services, rexec/rlogin/rsh), sostituendoli con alternative sicure (es. SSH).
- Applicare la segmentazione di rete e regole firewall restrittive, esponendo solo le porte strettamente necessarie e limitando l'accesso ai servizi amministrativi (SSH, RPC, SMB) a IP e reti fidate.
- Mantenere un programma di patch management regolare per tutti i servizi esposti (FTP, SMB, DNS, ecc.), verificando periodicamente la presenza di vulnerabilità note (CVE).
- Eseguire periodicamente vulnerability assessment interni, per individuare proattivamente la stessa superficie di attacco visibile a un potenziale aggressore esterno.

7. Conclusioni

L'analisi della cattura ha permesso di identificare con elevata confidenza un'attività di port scanning automatizzato condotta dall'host 192.168.200.100 nei confronti dell'host 192.168.200.150, riconducibile alla fase di ricognizione di una possibile catena di attacco. Sebbene la cattura non documenti fasi successive di exploitation, la superficie di servizi esposta dal target in particolare la

presenza di protocolli legacy insicuri rappresenta un rischio concreto qualora l'attività di ricognizione fosse seguita da tentativi di sfruttamento mirato.

Si raccomanda pertanto l'adozione tempestiva delle misure di rilevamento e hardening indicate al capitolo 6, al fine di ridurre sia la probabilità di successo di un attacco futuro sia il suo potenziale impatto.